Providers, statements, matching and suspense: review and plan of action

Prepared: 8 September 2026. **Package:** PAY. **Status:** SOURCE_REVIEW_AND_FOCUSED_VERIFICATION; implementation not started by this run.

1. Assessment and scope

This is a source review and focused local verification, not a full runtime certification. Database clients in the selected tests are mocked or injected. No deployed database, authenticated browser, live provider, production telemetry, restore rehearsal or qualified statutory approval was inspected in this run. Unexecuted scenarios below are acceptance requirements, not test results. No application code, migration, business record or deployment is changed by this report.

Accountable roles: Payments engineering and reconciliation controller. **Catalog coverage:** payment_reconciliation

Selected verification: 49 passed, 0 failed in the selected suite. Test source. This package owns or consumes PM-CACHE-001.

The highest-risk review questions are accepted request, settled money and reconciled evidence are separate states; test tampering, duplicate files, concurrent residual allocation and stale sign-off; unknown provider outcomes require investigation before any duplicate-risk retry.

2. Source and architecture map

The source inventory contains 50 matching files, including tests and supporting files. 6 sources were hashed and indexed for targeted review. Prefix inventory counts are discovery aids, not reviewed-file counts. The full list and source hashes are in the source manifest.

Layer	Current source/navigation anchor	Evidence boundary
services	services/reconciliation/payment-reconciliation-manual-match.service.ts	194 lines; SHA-256 e5bb212aba42…
hooks	hooks/payments/usePaymentReconciliationDashboard.ts	234 lines; SHA-256 945f52356a85…
actions	actions/payments/reconciliation.actions.ts	379 lines; SHA-256 1d1253a4321b…
actions	actions/payments/reconciliation-workbench.actions.ts	38 lines; SHA-256 5dd107a1431d…
hooks	hooks/payments/usePaymentReconciliationWorkbench.ts	36 lines; SHA-256 382c709c4433…
components	components/finance/PaymentReconciliationWorkbench.tsx	1926 lines; SHA-256 ff29e526bcdd…

Route/API paths must be expanded from callers; absence from the selected prefix inventory is not a declaration that none exist.

Data declarations

Schema model	Selected declared storage/relationship facts
ProviderAccount	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@unique([organizationId, providerCode]); @@unique([organizationId, paymentRailId, externalAccountHash])
SettlementAccount	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@index([organizationId, providerAccountId, approvalStatus]); @@index([organizationId, ledgerAccountId])
ProviderEvent	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); amount Decimal? @db.Decimal(14, 2); feeAmount Decimal? @db.Decimal(14, 2)
StatementFile	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@unique([organizationId, providerAccountId, fileHash]); @@index([organizationId, providerAccountId, status, periodStart])
StatementLine	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); statementFile StatementFile @relation(fields: [statementFileId], references: [id], onDelete: Cascade); amount Decimal @db.Decimal(14, 2)
PaymentTransaction	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); legacyPayment Payment? @relation(fields: [legacyPaymentId], references: [id], onDelete: SetNull); providerAuthorityEvent ProviderEvent? @relation("PaymentTransactionAuthorityEvent", fields: [organizationId, providerAuthorityEventId], references: [organizationId, id], onDelete: Restrict)
MatchRecord	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); confidence Decimal @default(0) @db.Decimal(5, 2); amountMatched Decimal? @db.Decimal(14, 2)
SuspenseItem	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); amount Decimal @db.Decimal(14, 2); @@index([organizationId, status, severity, createdAt])
ReconciliationRun	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); totalInternalAmount Decimal @default(0) @db.Decimal(14, 2); totalExternalAmount Decimal @default(0) @db.Decimal(14, 2)
PaymentException	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@index([organizationId, status, severity, createdAt]); @@index([organizationId, ownerId, status, slaDeadline])
PaymentReconciliationInboxItem	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@unique([organizationId, source, idempotencyKey]); @@index([organizationId, status, nextAttemptAt])

These are schema declarations. Exact migration application, actual constraints/indexes, row populations, query plans and direct-write bypasses remain unverified. See the platform package for migration/restore ownership.

Workflow trace and handoffs

The diagram is the review boundary and required end-to-end trace. Source links and selected tests substantiate only the portions described in this report; it does not claim every edge was exercised.

```
flowchart LR
  A["Business trigger / source"] --> B["Fresh tenant and role authority"]
  B --> C["PAY: owning domain service"]
  C --> D["Transaction and source evidence"]
  D --> E["Event / dependent workflow"]
  D --> F["Read model / query scope"]
  F --> G["UI / export / recovery"]
  E --> H["Reconciliation / assurance"]
```

Workflow	Expected outcome	Evidence disposition
PAY-FLOW-1	Authenticate and persist provider events and statement identities	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified
PAY-FLOW-2	Match whole or partial amounts and fees with independent approval where required	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified
PAY-FLOW-3	Resolve suspense and sign off against current evidence revision	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified

Integration contracts: IAM — Identity, tenant access, settings and administration; MOD — Module lifecycle, packaging and billing boundaries; EVT — Events, recovery, migrations and platform operations. These identify validation/ownership interfaces, not permission to duplicate their implementations. Accounting remains owned by the existing accounting roadmap.

Graph navigation: graph_actions.json node `payments_reconciliation_workbench_actions_ts`, community 132 (L1); graph_actions.json node `payments_reconciliation_workbench_actions_getpaymentreconciliationworkbenchaction`, community 132 (L35); graph_components.json node `finance_paymentreconciliationworkbench_tsx`, community 13 (L1); graph_components.json node `finance_paymentreconciliationworkbench_inputdate`, community 13 (L90); graph_hooks.json node `payments_usepaymentreconciliationdashboard_ts`, community 2 (L1); graph_hooks.json node `payments_usepaymentreconciliationdashboard_unwrappaymentreconciliationactionresult`, community 2 (L28). Graph extracts predate this review and are not runtime proof.

3. Controls to preserve

The following assertions passed against mocks/injected clients in this run. Preserve their contracts while extending validation; test names are not broader certification claims.

- manual reconciliation allocation controls turns a raw PostgreSQL serialization conflict into safe retry without masking other query failures.
- manual reconciliation allocation controls rejects a missing organization before reading payment or proposal data.
- manual reconciliation allocation controls propagates authority read failures without reverting to legacy grants.
- manual reconciliation allocation controls rejects non-writable module access {"status":"read_only"} before proposal evidence is read.

4. Findings, limitations and risks

PM-CACHE-001 — Several sensitive query families omit tenant or actor identity

CREDIBLE_RISK_REQUIRES_RUNTIME_VALIDATION · P1. Confidence: High for missing key dimensions; cross-session disclosure not demonstrated. Likelihood: Depends on client lifetime and identity-transition behavior; unmeasured.

Evidence: hooks/payments/usePaymentReconciliationDashboard.ts:19; hooks/payroll/usePayrollWorkbench.ts:16; hooks/finance/useFinanceDashboard.ts:7; hooks/posHooks/useOfflineSync.ts:75; lib/providers/query-provider.tsx:14.

Trigger: Organization, actor, permissions or entitlements change while the QueryClient survives.

Expected: Scope-changing transitions cannot render old protected results; result-changing scope belongs in cache identity with cancellation/removal where necessary.

Observed: Payment and payroll keys use fixed prefixes (and limits/IDs); finance/offline keys include filters but no explicit tenant/actor. QueryProvider creates one client with useState. This review did not execute every identity-change path or establish whether navigation remounts/clears it.

Cause / uncertainty: Server-inferred authority is not represented explicitly in these client keys.

Consequences: Stale financial or personnel data may be shown in the wrong context if the client survives. Severity justifies early validation, but this is not a confirmed disclosure incident.

Existing mitigation: Server actions retain authorization and some keys have location/run filters; full reloads could clear caches but are not a complete demonstrated contract.

Correction: Trace every switch/logout/revocation path, then centralize scoped keys and query cancellation/removal; avoid retaining previous protected data across authority changes.

Acceptance: Same-browser two-tenant/actor tests show no old values during loading, errors or revocation; all impacted views refresh after writes.

Owner / estimate: Shared frontend/IAM owner plus affected module owners; 2–3 days to validate; 3–7 engineering days if shared lifecycle correction is required. Estimates are planning judgments, not booked capacity.

Data and rollout: No data mutation required; assess exposure only if runtime reproduction identifies it.

Related earlier work: ACC-010, ACR-22

Additional module scenarios still requiring verification

- **PAY-VERIFY-1:** Accepted request, settled money and reconciled evidence are separate states. Owner: Payments engineering and reconciliation controller. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.
- **PAY-VERIFY-2:** Test tampering, duplicate files, concurrent residual allocation and stale sign-off. Owner: Payments engineering and reconciliation controller. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.
- **PAY-VERIFY-3:** Unknown provider outcomes require investigation before any duplicate-risk retry. Owner: Payments engineering and reconciliation controller. Status: UNVERIFIED. Evidence required: a synthetic

failure/success pair and source-to-result tie-out.

5. Layer and reviewer dispositions

Lens	Current disposition and remaining proof
Architecture, backend and integrations	Sources/call boundaries inventoried; selected service assertions above. Trace alternate entry points and every handoff before whole-domain approval.
Database, migration and integrity	Named schema models indexed. Deployment, tenant-consistent foreign keys, locking, rollback, scale and backfill/restore not verified.
IAM, privacy, fraud and controls	Apply direct denied-no-read/no-write, role revocation, maker-checker and export redaction tests. A server guard or hidden button alone is insufficient.
Frontend, queries and design system	Client/action entry above inspected statically where present; cache identity, mutation effects and source truth must be traced into actual screens.
UX, accessibility, EN/FR and content	Authenticated role tasks, keyboard/focus, mobile and localized state behavior not executed; no accessibility claim.
Product and business process	Three explicit workflows and supported-scope decisions above; measure task completion and support burden before redesign.
Accounting and financial controls	Source/amount/quantity/period/currency tie-outs and correction ownership apply; reuse ACC/ACR controls.
Statutory and country review	No new statutory interpretation is made. Escalate any discovered country-specific output to CMP/qualified review.
QA and release	49 passed, 0 failed in the selected suite. linked test source. Unit results do not replace integrated evidence.
SRE, performance and cost	No latency/load/restore measurements; establish bounded reads, worker age/error metrics, alerts, retries and support ownership before rollout.
AI and agent authority	AI model behavior is not applicable unless a connected agent consumes this module; review that access contract without adding AI features.
Packaging, billing and operations	Confirm actual catalog/entitlement scope and mandatory retained obligations. Provider billing, adoption and customer outcomes are unverified.

6. Ordered execution plan

PM-PAY-01 — Bind current scope, owners and candidate

Status: READY. **Owner:** Payments engineering and reconciliation controller. **Effort:** 1–2 reviewer days.

Deliverable: Confirm every listed workflow, supported variant and relevant prior ACC/ACR or STQ-RM item; hash current sources, map entry points and name a domain reviewer.

Acceptance: All material paths have active/legacy/deferred status; no existing change is overwritten.

Prerequisite: Candidate/owner availability; existing historical evidence is a lead..

PM-PAY-02 — Reproduce priority risks and freeze contracts

Status: PLANNED. **Owner:** Payments engineering and reconciliation controller. **Effort:** 2–4 reviewer/QA days; isolated environments may extend elapsed time.

Deliverable: Accepted request, settled money and reconciled evidence are separate states; Test tampering, duplicate files, concurrent residual allocation and stale sign-off; Unknown provider outcomes require investigation before any duplicate-risk retry. Reproduce all linked findings before prescribing data repair.

Acceptance: A scenario ledger records expected/observed behavior, source IDs, denied side effects and remaining blockers.

Prerequisite: PM-PAY-01.

PM-PAY-03 — Implement verified corrections and investigate affected data

Status: CONDITIONAL_ON_CONFIRMED_FINDINGS. **Owner:** Payments engineering and reconciliation controller. **Effort:** Use linked finding estimates; otherwise estimate after diagnosis.

Deliverable: Correct the smallest owning boundary; preserve domain history, shared controls and public contracts. Investigate historical impact separately and design reversible repair only if needed.

Acceptance: Focused regression, cross-module tie-out and review prove the correction; no speculative implementation or silent historical rewrite.

Prerequisite: PM-PAY-02. If no defect is confirmed, record a reviewed no-change disposition; this satisfies the decision step without speculative work.

PM-PAY-04 — Verify integrated release and controlled rollout

Status: PLANNED. **Owner:** Payments engineering and reconciliation controller. **Effort:** 2–3 reviewer/QA days plus the real operational cycle.

Deliverable: Run isolated DB failure/concurrency scenarios, authenticated role/locale/cache tests, representative performance/export checks and recovery rehearsal. Pilot the agreed supported scope.

Acceptance: No unexplained material mismatch, unauthorized effect or stale evidence claim; domain reviewer and operations owner accept scoped results.

Prerequisite: PM-PAY-03.

Existing accounting and enterprise roadmap estimates must be deduplicated: PM findings linked to ACC/ACR or STQ-RM reuse the owning task. Reviewer-day estimates here are not engineering effort for a complete rewrite and must not be summed with the accounting roadmap as if independent.

7. Data correction, rollout and completion

Investigate exposure using source IDs, time/currency scope, counts and reconciled totals before proposing any repair. Preserve original records, hashes and exports; use reviewed corrective transactions or versioned migration only where necessary. Rehearse backup/restore and rollback in a disposable environment. Code correction and historical reconciliation are separate acceptance items. A query/display issue alone does not justify rewriting financial history.

Start with an agreed eligible pilot and observe a complete relevant cycle (sale/refund/shift; receiving/invoice/payment; payroll period; or close). Stop expansion on unauthorized effects, unexplained material mismatches, duplicate effects or stale proof. Record incident owner, recovery route and the data needed for investigation. No pilot or release is authorized or completed by this document.

Completion requires disposition for every workflow, current-source evidence for each significant claim, tested or explicit blocked failure scenarios, domain-reviewed corrective work and an understood operational handoff. The tailored audit prompt provides the full repeatable execution brief.

8. Evidence and provenance

Commit: `a05a41ef66cd5d98fd69ae3df18225795f912232`; branch: `codex/migration-control-plane-release-2026-08-29`. Initial capture: 2026-09-08T14:41:48.494Z. Dirty workspace preserved; claims bind to file hashes, not clean HEAD. Unit command: 2026-09-08T14:43:08.844Z to 2026-09-08T14:44:14.458Z; exit 1. See exact command, assertion results, test log and shared evidence index. Historical reports were used for navigation and work deduplication; their earlier pass counts are not included in this run.